HIPAA Compliance in the Software World

Presented by
Terry Long, President

Futura International, Inc.
A leader in HIPAA Software development and compliance

HIPAA's Primary Objectives

- **Security**

  protect the security and privacy of healthcare information

- **Efficiency**

  improve the efficiency of healthcare delivery by standardizing electronic data interchange (EDI)

Meeting HIPAA's Objectives

(by safeguarding your business, your data, and your computers)

What is the greatest threat to meeting these objectives?

THE INTERNET

Security Primer

- **Why isn't the Internet more secure**
  1. It was designed by academics that never imagined it would become what it is today.
  2. Internet transmissions were originally meant to be read by anyone – like a postcard.

Security Primer

- **Why isn't the Internet more secure**
  1. It was designed by academics that never imagined it would become what it is today.
  2. Internet transmissions were originally meant to be read by anyone – like a postcard.
- **What's the good news?**

  Programmers have since created an array of technologies to protect users…

New Internet Protection Technologies

- **PGP Software**
  "Pretty Good Privacy" – encrypts Email and files to keep them secure

BUT…

HIPAA does not accept PGP as a proper security consideration

New Internet Protection Technologies

- **SSH**

  "Secure Shell" program – lets system administrators access remote servers safely

New Internet Protection Technologies

▲SSL

"Secure Sockets Layer" – an industry-standard protocol used to transfer private information over the Internet

Provides:

- Data encryption
- Server authentication
- Message integrity
- Optional client authentication for a TCP/IP connection

In addition:

- SSL is included in all major browsers
- Most current browsers enable the preferred128-bit strong encryption

BUT… This architecture lacks efficient integrity controls and message authentication capabilities

New Internet Protection Technologies

▲VPN

"Virtual Private Network" – gives users the equivalent of a private line (access) to a corporation or service provider

Provides:

- Greater security for Email and file transfers (e.g., claims submissions)

In addition:

- Generally used by larger organizations as it allows for the transmission of large amounts of data
- Larger organizations use this solution because they have greater resources to implement it

New Internet Protection Technologies

▲VPN

"Virtual Private Network" – gives users the equivalent of a private line (access) to a corporation or service provider

Provides:

- Greater security for Email and file transfers (e.g., claims submissions)

In addition:

- Generally used by larger organizations as it allows for the transmission of large amounts of data.
- Larger organizations use this solution because they have greater resources to implement it

BUT… This method is more difficult than SSL – particularly in configuration and firewalls

New Internet Protection Technologies

- **PKI**

  "Public Key Infrastructure" – the most secure and stringent of all the other methods

BUT…

This technology requires a great deal of administration support to provide alarms and proper event reporting

So… What IS Secure?

- Online Banking
- Online Trading
- Online Shopping

Why are these secure?

Monetary transactions/commercial sites use SSL technology to protect their data

So… What is NOT Secure?

- Web-based Email
- Stock Portfolio Pages
- Search Engines

Why aren't these secure?

High-volume sites can't handle sophisticated security routines

What can your healthcare organization do to satisfy HIPAA security requirements for EDI transactions?

1. Identify the organizations with which you will exchange healthcare data.
2. Determine the volume of data exchanged or to be exchanged with each “trading partner”.
3. Carefully document the data exchange methods currently in use with “trading partners” (e.g., clearinghouse, dedicated network, etc.)
4. Determine how the data will be translated into an ANSI X 12 format (e.g., EDI VAN – Electronic Data Interchange Value Added Network or clearinghouse)
5. Check with your current software vendor as to how they will be providing the EDI translation software.
6. **Refer to the OPGA’s HIPAA Guide for more details as well as specific implementation steps.**

Safe Surfing

What can you do to protect you, your business, and your data when you are surfing the net?

Safe Surfing

What can you do to protect you, your business, and your data when you are surfing the net?

Look for the lock!

Both Internet Explorer and Netscape display a lock icon at the bottom of the screen to indicate each secure web page.

Secure = a site uses SSL to send pages and receive your requests

Safe Surfing

What can you do to protect you, your business, and your data when you are surfing the net?

Look for the lock!

Both Internet Explorer and Netscape display a lock icon at the bottom of the screen to indicate each secure web page.

Secure = a site uses SSL to send pages and receive your requests

TIP: ***To further ensure security, ALWAYS TYPE a URL or use a bookmark you created when you log on to any site. NEVER CLICK on a link sent you via Email.***

Other Security Considerations

- **Access Controls**
  The ability to convert data into a format that cannot be read until the data is decrypted using special tools or “keys”

- **System Requirements**
  Alarm: Triggers alerts that are sent to designated individuals if certain security conditions are encountered (e.d., a security breach)

- **Audit Trail**
  Detailed communications activity log

Other Security Considerations
(continued)

- **Event Reporting**
  Provides information about key events. For instance, multiple logon failures by the same person or significant probing by unknown “intruders” are reported (i.e., perhaps indicating someone trying to hack into the system)

- **Security Requirement Entity Authenticity**
  Ensures that the recipient of a transaction knows that the source of the a message or the named originator is exactly whom they claim to be and not some other person or entity

The Importance of Passwords

****

Most systems support passwords that are a combination of letters and numbers. Some accept 10 or more characters, some accept no more than 6.

How do I choose a password?

Make sure that it is something that you can easily remember

BUT…

DON'T MAKE IT TOO OBVIOUS SO THAT SOMEONE ELSE CAN EASILY GUESS IT!

Password DOs

- Use abbreviations instead of whole words
- Mix upper and lowercase letters
- Include special characters (e.g., punctuation)
- Substitute numbers for sounds (e.g., 2 instead of to)

(Ex: a strong password = 7sf30iq8zk3e)

Password DON'Ts

- Never use your nickname or middle name
- Never use the name of your child or significant other
- Never use common dictionary words (e.g., zebra, meditate, hologram)
- Never use your date of birth or anniversary
- Never write it down

Other Password Safeguards

- Find a safe place to store them
- Top Secret (free:www.pirem.com) uses strong encryption to secure your passwords

Securing Your Connection

Always on, Always Vulnerable

- **Broadband connections are much riskier than dial-up connections:**
  - BB service providers often assign your computer and identifying number (I.e., IP address) that makes it easier to find
  - Users often leave BB- connected (and unattended) PC's on all the time

Securing Your Connection

Head Off Potential Problems

- **Use a Dynamic IP**

  Ask your broadband service provider to assign you a dynamic (vs. a static) IP address.
  This means that every time you go online, you'll do so under a different IP address – making it more difficult for hackers to "follow your scent"

Securing Your Connection

Head Off Potential Problems

- **Use a Dynamic IP**
  Ask your broadband service provider to assign you a dynamic (vs. a static) IP address.
  This means that every time you go online, you'll do so under a different IP address – making it more difficult for hackers to "follow your scent"

- **Buy a Router**
  Normally used to connect multiple PC's, a router can also help make your computer "invisible" to hackers

Securing Your Connection

Head Off Potential Problems *(continued)*

- **Never leave your PC connected to a file-sharing service (e.g., Kazaa, Limeware, Morpheus)**

  All of the above use technology that allow more than your MP3s to be shared – without your knowledge or consent!

What about Firewalls?

Do I need one?

- Large companies rely on firewall software to secure their computer networks
- Smaller offices, as well as home computers, should have similar protection

What about Firewalls?

Do I need one?

- Large companies rely on firewall software to secure their computer networks
- Smaller offices, as well as home computers, should have similar protection

But before you go out and buy it…

Be aware that YOU MAY ALREADY HAVE IT!

The newest operating systems from Microsoft (e.g., Windows XP) already have security systems built in. Advanced virus protection software (e.g., Norton Virus Scan) will also provide protection.

What about Viruses?

How do I Immunize my computer?

- **Get Anti-virus software (available from many sources):**
  McAfee (www.mcafee.com)
  Symantec (www.symantec.com)
  Trend Micro (www.trendmicro.com)
  ZoneLabs (www.zonelabs.com)*

- **General Cost of Virus Protection…**

  $40 or more

* Zonelabs offers a basic security package for free, and a more complete software suite including anti-virus software for $50

What about Viruses? *(continued)*

Is there anything else I can do?

- **Don't Preview Email**

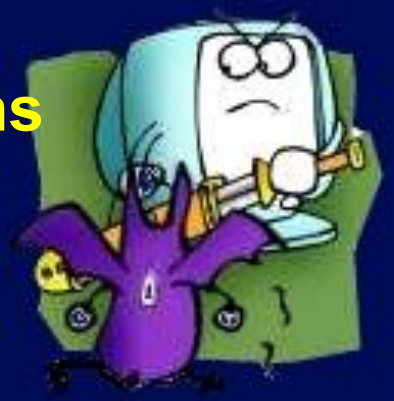
  Some Email programs like Microsoft Outlook allow you to "preview" your Email attachments… BAD IDEA!

- **Delete (without opening) any Emails with suspicious or unfamiliar subject lines or senders**

  There are many computer viruses PURPOSELY sent through Email messages

- **Avoid Microsoft Software Applications**

  Certain Microsoft products are especially vulnerable to viruses. Alternatives such as Eudora or Netscape are recommended for Email, and Netscape for browsing.



Some Additional Security Recommendations

Instant Messaging Can Instantly <u>Put Your Data At Risk</u>

- **Instant messaging programs contain security risks**
  (e.g., AOL, ICQ, Instant Messenger, Yahoo Messenger, etc.)
- **Remember that anything you send over an IM program can be accessed by a third party**
- **Some of these programs reveal your location on the Internet**

  (making it easy for hackers to find and attack your computer)

Final Tips about Protecting Your Data

- **Don't overuse IM**
  Save the important or sensitive discussions for the phone or meetings
- **Don't Email sensitive medical information to a patient**
  Schedule an in-office appointment
- **Make sure you have Internet Disclosure documents in your Policies and Procedures Manual**

Final Tips about Protecting Your Data

(continued)

- **Educate your staff about Internet dangers**
- **Get heavy-duty software for communications**

  If your company uses IM for inter-office communications, have your IT staff to install a heavy-duty corporate system such as IBM's Lotus Notes

Your Primary Objectives

- **Security**

  Do everything you need to do to protect your system as previously detailed

- **Efficiency**

  Investing time and money in the appropriate programs and systems will save you time and money – AND headaches in the end

Summary

The Right Stuff

Summary

The Right Stuff

Remember:

Summary

The Right Stuff

Remember:

Making the best preparations up front, using newest technologies, and taking a few simple precautions will keep your data, your patients, and your business safe and protected.

QUESTIONS

?